

Lab 07 VM administration and encryption

AI for IT Security Professionals | TGS-2023039344 | v6.0

Purpose and output

Create a VM control evidence matrix. This lab supports LO2. It uses a simplified deterministic teaching model, not a trained AI system or full Azure emulator. The AI review is a separate exercise using the included prompt.

Requirements

Python 3.10 or later, a text editor and this entire folder. No packages, network access or API key are required for the baseline. On Windows use `py -3` if `python3` is unavailable. An approved AI tool is optional; the trainer can provide a review response for critique. Azure exercises require the trainer-assigned subscription, permission and feature entitlement. Record an exact blocker where unavailable; never describe an unperformed test as passed.

Folder contents

- `mock-data.json`: synthetic input with no real personal data or credentials.
- `analyse.py`: runnable analysis for this lab only.
- `expected-results.json`: expected baseline and source checksum.
- `ai-review-prompt.txt`: evidence-constrained AI review prompt.
- `evidence-template.md`: your deliverable template.
- `INSTRUCTIONS.md` and `INSTRUCTIONS.pdf`: the same procedure in two formats.

1 Prepare a working copy

Copy this whole folder to a location you can edit. Open a terminal in the copied folder. Confirm Python and inspect the data before running code.

```
python3 --version
python3 -m json.tool mock-data.json
```

Identify the record IDs and explain the meaning of each field. All values are invented classroom fixtures. Open `analyse.py` in the editor and locate the decision rule. It reads a local JSON file and writes a local report.

2 Run the baseline

```
python3 analyse.py --input mock-data.json --output results.json
```

Open `results.json`. The expected decisions in output order are: `BASELINE_OK`, `PUBLIC_ADMIN`, `LONG_WINDOW`, `ENCRYPTION_REVIEW`. The `source_sha256` binds the report to the exact input bytes. Compare against the supplied baseline:

```
python3 -c "import json; a=json.load(open('results.json')); b=json.load(open('expected-results.json')); assert a==b; print('BASELINE PASS')"
```

A pass proves this fixture was processed as specified; it does not prove an Azure control was deployed. Copy the input checksum and decision rows into your evidence template.

3 Trace the mechanism

Bastion access path

A managed jump path can remove direct public administrative exposure on a VM.

Contract: `vm_public_ip`, `admin_port`, `bastion_path`

Accepted case: The VM has no public IP and uses the approved Bastion path.

Counterexample: TCP 3389 is open from the internet alongside Bastion.

Diagnosis: Remove the direct exposure after validating the managed access path and recovery plan.

Evidence: Capture NIC public IP state and effective inbound rules.

Just in time administration

Time-limited access narrows source and duration for administrative ports.

Contract: source_cidr, port, requested_minutes, expiry

Accepted case: One approved source opens port 22 for 30 minutes.

Counterexample: 0.0.0.0/0 is allowed without an expiry.

Diagnosis: Close the broad rule and verify access expires; approval is distinct from successful use.

Evidence: Keep request, approval, start, expiry and post-expiry denial evidence.

Encryption and identity

Encryption protects stored bytes while identity controls authorised plaintext access.

Contract: encryption_state, key_reference, principal

Accepted case: Encrypted disks remain protected by scoped operator access.

Counterexample: A broad identity reads data legitimately despite encryption.

Diagnosis: Reduce identity permissions; encryption cannot compensate for authorised over-access.

Evidence: Separate encryption configuration evidence from access test results.

4 Change one input and test the consequence

Save a copy of mock-data.json as changed-data.json using the editor. Set vm-b public_admin to false.

LONG_WINDOW must remain; closing one exposure does not satisfy all controls.

```
python3 analyse.py --input changed-data.json --output changed-results.json
```

Compare decisions and source hashes with the baseline. Identify the exact expression in analyse.py responsible for the changed behaviour. Do not overwrite expected-results.json to make a failing baseline pass. Restore the original fixture if you edited it accidentally.

5 Review AI claims against evidence

Open ai-review-prompt.txt. In an organisation-approved AI tool, submit the prompt with the synthetic input and result only. Record the tool/model name, date and prompt version if available. If no approved AI tool is available, manually draft a tentative analyst summary and label it as a human exercise.

For each returned claim, record its cited ID, the actual field value, whether the claim follows, and any correction.

Reject conclusions unsupported by the records even when the model is confident. Include one alternative explanation. The AI response is a proposal; it has no authority to approve or execute a security action.

6 Verify the corresponding operational control

Azure procedure E Verify VM administration and encryption

1. Open the assigned VM > Networking. Record its NIC, subnet and whether a public IP is attached. Inspect effective inbound rules for ports 22 and 3389.
2. Review the provisioned Bastion path and its VNet/subnet placement. Connect to the training VM using the approved identity if access is allocated. Do not record credentials.
3. Identify any direct public administrative rule that remains. Propose its removal, verify an alternative access/recovery route with the trainer, and change only an allocated lab rule.
4. In Defender for Cloud, locate the VM's Just-in-Time access configuration where the plan supports it. Request a trainer-approved short access window from a single approved source. Record port, source and expiry.
5. Test the access while active. After expiry, test a new connection and record denial; an existing connection can behave differently from a new one. Capture the policy and actual result separately.
6. VM > Disks: inspect encryption at rest and any encryption-set/key reference. Determine which layer is being shown rather than assuming all encryption options are equivalent.
7. Explain why a legitimately authorised broad identity can still access plaintext despite encryption. Record separate identity and encryption evidence.

8. Restore lab-only access changes and verify that no temporary administrative rule remains. Record feature/licence blockers without claiming a successful deployment.

For every screenshot or export, record resource scope, UTC time and expected versus observed result. Redact personal data and secrets. If blocked, record the exact error, missing permission/licence, what could be inspected, and the unverified outcome. Ask the trainer to provide an authorised sandbox demonstration where the assessed ability cannot otherwise be evidenced.

7 Submit evidence and clean up

Complete evidence-template.md with baseline, changed result, AI claim review and Azure evidence or clearly labelled limitations. Keep results.json and changed-results.json with your submission. Check that your conclusion distinguishes an observed fact from a hypothesis. Remove only resources or assignments you created with trainer approval; do not delete shared training infrastructure.

Acceptance checks

- The unchanged fixture produces the exact expected report.
- The changed fixture produces the explained result and a different input hash.
- At least one AI or analyst claim is checked against a specific record and field.
- The report states simulation, Azure verified or blocked for each relevant claim.
- The output is a VM control evidence matrix with an owner, evidence and remaining uncertainty.

Troubleshooting

- Python not found: install the trainer-approved Python distribution or use py -3 on Windows.
- File not found: open the terminal in this lab folder; check the input filename.
- JSON parse error: validate with python3 -m json.tool changed-data.json; use lowercase true and false in JSON.
- Baseline mismatch: restore the supplied fixture and inspect the first differing decision; never edit the expected file.
- Azure denial or missing feature: capture the exact error and scope. A blocker is a limitation, not proof of competence or deployment.
- AI invents evidence: reject the claim, cite the missing ID, and request an evidence-limited revision.

References

The Learner Guide contains the complete source register and the lecture explanations for this lab. Original examples are adapted from the supplied Azure and AI-security references. Product behaviour should be checked against current Microsoft Learn documentation before a real deployment.